

SECURITY ARCHITECTURE

1. Executive Summary

This document explains the security framework adopted for the AWS cloud environment within the assigned project. It takes a multi-layered defence approach to build an environment through identification, segregation, encryption, and continuous monitoring.

The four security pillars addressed are:

- Identity & Access Management (IAM) with least-privilege group policies
- Network Security using VPC segmentation, Security Groups, and subnet isolation
- Encryption & Key Management using AWS KMS, EBS encryption, and SSM-KMS for S3
- Security Operations (SecOps) using CloudTrail, CloudWatch dashboards, and metric filters

2. Architecture Overview

The architecture is built on the following security principles:

- **Least Privilege** - no user or service has more permissions than strictly required
- **Defence in Depth** - multiple security layers, so no single failure creates a breach
- **Encryption Everywhere** - data encrypted at rest and in transit
- **Zero Trust Mindset** - explicit verification for all network flows
- **Continuous Monitoring** - real-time alerting on anomalous activity

The AWS environment is structured as follows:

- A single VPC segmented into a public subnet (web tier) and a private subnet (database tier)
- An Internet Gateway attached to the public subnet for controlled external access
- Security Groups acting as stateful virtual firewalls for each resource tier
- AWS KMS-managed encryption keys protecting data at rest and in transit
- CloudTrail logging all API calls, feeding CloudWatch for real-time alerting

3. Identity & Access Management

Group	Purpose	Key Permissions
Admin	Full infrastructure management	EC2, VPC, IAM (limited), KMS admin
Developer	Application deployment and testing	EC2 read/start/stop, S3 read/write (specific buckets), SSM
Auditor	Read-only compliance and log review	CloudTrail read, CloudWatch read, Config read, S3 read

IAM Group Structure

IAM user groups (4) [Info](#)

Delete

Create group

A user group is a collection of IAM users. Use groups to specify permissions for a collection of users.

Q Search

< 1 > ⚙

☐	Group name	▲	Users	▼	Permissions	▼	Creation time	▼
☐	AdminGroup		1	...	Defined		2 days ago	
☐	AuditorGroup		1	...	Defined		Yesterday	
☐	DeveloperGroup		1	...	Defined		Yesterday	
☐	SOCAnalystGroup		1	...	Defined		Yesterday	

User Groups

AuditorGroup [Info](#)

Delete

Summary

User group name

AuditorGroup

Creation time

May 16, 2026, 13:21 (UTC+05:30)

ARN

arn:aws:iam::660830512345:group/AuditorGroup

Edit

Users (1)

Permissions

Access Advisor

Users in this group (1)

Remove

Add users

An IAM user is an entity that you create in AWS to represent the person or application that uses it to interact with AWS.

Q Search

< 1 > ⚙

☐	User name	↗	▲	Groups	Last activity	▼	Creation time	▼
☐	auditor1			1	None		Yesterday	

Auditor Group

DeveloperGroup
Info
Delete

SummaryEdit

User group nameDeveloperGroup

Creation timeMay 16, 2026, 13:21 (UTC+05:30)

ARNarn:aws:iam::660830512345:group/DeveloperGroup

Users (1)PermissionsAccess Advisor

Users in this group (1)RemoveAdd users

An IAM user is an entity that you create in AWS to represent the person or application that uses it to interact with AWS.

Search

< 1 > ⚙

☐	User name ↗	▲	Groups	Last activity ▼	Creation time ▼
☐	developer1		1	None	Yesterday

Developer Group

AdminGroup
Info
Delete

SummaryEdit

User group nameAdminGroup

Creation timeMay 16, 2026, 12:11 (UTC+05:30)

ARNarn:aws:iam::660830512345:group/AdminGroup

Users (1)PermissionsAccess Advisor

Permissions policies (1) InfoSimulate ↗RemoveAdd permissions ▼

You can attach up to 10 managed policies.

Search

Filter by TypeAll types ▼

< 1 > ⚙

☐	Policy name ↗	▲	Type ▼	Attached entities ▼
☐	 AdministratorAccess		AWS managed - job function	4

Admin Group

Least-Privilege Policy Controls

- Explicit Deny statements block privilege escalation paths for Developer and Auditor groups
- Admin group uses condition keys (aws:MultiFactorAuthPresent: true) to enforce MFA
- No wildcard (*) resources in any Developer or Auditor policy
- Periodic access reviews are recommended quarterly via IAM Access Analyzer

4. Network Security

Subnet	Type	Hosts	Internet Access
Public Subnet	Public	Public Instance	Yes
Private Subnet	Private	Private Instance	No

VPC dashboard

Virtual private cloud

Subnets

Route tables

Internet gateways

Egress-only internet gateways

Carrier gateways

DHCP option sets

Elastic IPs

Managed prefix lists

NAT gateways

Peering connections

Route servers

Security

Network ACLs

Security groups

acl-04a4539da012f197f

IPv6 CIDR (Network border group)

No

Network Address Usage metrics

Disabled

Route 53 Resolver DNS Firewall rule groups

10.0.0.0/16

Encryption control ID

Encryption control mode

Owner ID

660830512345

Resource map

CIDRs

Flow logs

Tags

Integrations

Subnets (2)

Subnets within this VPC

us-east-1f

public-subnet-sprint

private-subnet-sprint

Route tables (4)

Route network traffic to resources

rtb-0dd7ed6587f1dd235

public-route-sprint

private-route-sprint

rtb-0767033533af110f6

Network Connections (2)

Connections to other networks

igw-sprint

NAT-gw-sprint

VPC

Security Groups (3)

Find security groups by attribute or tag

VPC ID = vpc-0fb017b0c0ed0f3b5

Clear filters

Actions

Export security groups to CSV

Create security group

Name	Security group ID	Security group name	VPC ID	Description
jumpServer-sg-sprint	sg-023be6a132d103608	webServer-sg-sprint	vpc-0fb017b0c0ed0f3b5	SG for Web Server
privateEC2-sg-sprint	sg-09f64b2f8c09acf37	monitoring-sg-sprint	vpc-0fb017b0c0ed0f3b5	security group for Pi
default-sg-sprint	sg-05018de4b3634d3c0	default	vpc-0fb017b0c0ed0f3b5	default VPC security

Security Groups

Direction	Protocol	Port	Source/Destination	Purpose
Inbound	TCP	443	0.0.0.0/0	HTTPS traffic from internet
Inbound	TCP	80	0.0.0.0/0	HTTP (redirect to HTTPS)
Inbound	TCP	22	Admin IP only	SSH management access
Outbound	All	All	0.0.0.0/0	Outbound traffic

sg-0ad98b908d1e05a98 - websg

Actions

Details

Security group name
websg

Security group ID
sg-0ad98b908d1e05a98

Description
web security group

VPC ID
vpc-0110684f9a6e25521

Owner
200642811988

Inbound rules count
3 Permission entries

Outbound rules count
1 Permission entry

Inbound rules | Outbound rules | Sharing | VPC associations | Related resources - new | Tags

Inbound rules (3)

Manage tags | Edit inbound rules

Security group rule ID	IP version	Type	Protocol	Port range	Source
sgr-07b0b05ecd4fdc702	IPv4	HTTP	TCP	80	0.0.0.0/0
sgr-03cd38414a2e1c5e8	IPv4	SSH	TCP	22	136.232.87.234/32
sgr-0e8a98eccaba4dafa	IPv4	HTTPS	TCP	443	0.0.0.0/0

Security Group (Public Subnet)

Direction	Protocol	Port	Source/Destination	Purpose
Inbound	TCP	3306	Web Server SG only	MySQL from web tier only
Inbound	TCP	22	Admin IP only	SSH management access
Outbound	All	All	VPC CIDR only	Internal VPC traffic only

Details

Security group name
 monitoring-sg-sprint

Security group ID
 sg-09f64b2f8c09acf37

Description
 security group for Private Subnet

VPC ID
[vpc-0fb017b0c0ed0f3b5](#)


Owner
 660830512345

Inbound rules count
2 Permission entries

Outbound rules count
1 Permission entry

Inbound rules
Outbound rules
Sharing
VPC associations
Related resources - new
Tags

Inbound rules (2)


Manage tags
Edit inbound rules

Security group rule ID	IP version	Type	Protocol	Port range	Source	Description
sg-0955157466f4163ec	-	Custom TCP	TCP	3000	sg-023be6a132d10360...	-
sg-03c71dd32ab6ab9d5	-	SSH	TCP	22	sg-023be6a132d10360...	-

Security Group (Private Subnet)

5. Encryption Strategy & Key Management

Service	Encryption Method
EBS Volumes	AES-256 (EBS Encryption)
S3 Buckets	SSE-KMS

Key Management

- AWS KMS Customer Managed Keys (CMKs) used for all encryption operations
- Automatic key rotation enabled on the Admin CMK
- Key policies follow least-privilege: only designated IAM roles can use each key
- Key usage is logged via CloudTrail for complete audit trail

[Alt+S]

1

United States (N. Virginia)

skjam (660830512345)

skjam

> Key ID: 03c9294c-7f6a-4f76-8faf-fa0e10360076

03c9294c-7f6a-4f76-8faf-fa0e10360076

Key actions

Edit

General configuration

Alias

cybersec-trail

ARN

arn:aws:kms:us-east-1:660830512345:key/03c9294c-7f6a-4f76-8faf-fa0e10360076

Current key material ID

60272ea2c778b01f9fa4210a4017d59c6034df6d746929ebc8ef34c5c15e3708

Status

Enabled

Description

-

Creation date

May 16, 2026 15:55 GMT+5:30

Last used

13 minutes ago

Regionality

Single Region

Key policy

Cryptographic configuration

Tags

Key material and rotations

Aliases

Key policy

Edit

1 {

2 "Version": "2012-10-17",

3 "Id": "Key policy created by CloudTrail",

4 "Statement": [

5 {

Default encryption

Edit

Server-side encryption is automatically applied to new objects stored in this bucket.

Encryption type

Info

Server-side encryption with Amazon S3 managed keys (SSE-S3)

Bucket Key

When KMS encryption is used to encrypt new objects in this bucket, the bucket key reduces encryption costs by lowering calls to AWS KMS. [Learn more](#)

Enabled

Blocked encryption types

Info

Server-Side Encryption with Customer-Provided Keys (SSE-C)

In-progress change to default encryption

As announced in November 2025, we have started deploying an update that will block server-side encryption with customer-provided keys (SSE-C) by default for all new buckets and specific existing buckets. If you need to use SSE-C encryption, make sure that SSE-C is not selected under Blocked encryption types. [Learn more](#)

S3 Encryption

6. Security Operations & Monitoring

Metric Filter	What It Detects	Alarm Threshold
Root Account Access	Any API call or console login by the root user	1 occurrence
Unauthorised API Calls	AccessDenied or UnauthorizedOperation errors	5 occurrences in 5 min
IAM Role Change	CreateRole, DeleteRole, AttachRolePolicy, DetachRolePolicy	1 occurrence
Failed Login	Repeated ConsoleLogin failures (potential brute force)	3 failures in 5 min
Security Group Change	AuthorizeSecurityGroupIngress, RevokeSecurityGroupIngress, etc.	1 occurrence

Infrastructure Monitoring

- CloudWatch monitors EC2 CPU utilisation for the web server with threshold alarms at 80%
- Network In/Out metrics tracked to detect anomalous data exfiltration or DDoS traffic
- CloudWatch dashboard provides a unified SOC view of all security and performance metrics

The screenshot shows the AWS CloudTrail console interface. At the top, there's a navigation bar with the AWS logo, a search bar, and a user profile for 'skjam (660830512345)' in the 'United States (N. Virginia)' region. Below the navigation bar, the breadcrumb trail indicates the current location: 'CloudTrail > Trails > arn:aws:cloudtrail:us-east-1:660830512345:trail/SecurityMonitoringTrail'. The main heading is 'SecurityMonitoringTrail', with 'Delete' and 'Stop logging' buttons on the right. The 'General details' section contains several key-value pairs: 'Trail logging' is 'Logging' (with a green checkmark icon); 'Trail name' is 'SecurityMonitoringTrail'; 'Multi-region trail' is 'Yes'; 'Apply trail to my organization' is 'Not enabled'; 'Trail log location' is 'cybersecurity-cloudtrail-logs-sprint/AWSLogs/660830512345' (with a link icon); 'Last log file delivered' is 'May 18, 2026, 11:59:15 (UTC+05:30)'; 'Log file SSE-KMS encryption' is 'Enabled'; 'AWS KMS key' is 'arn:aws:kms:us-east-1:660830512345:key/03c9294c-7f6a-4f76-8faf-fa0e10360076' (with a link icon); 'AWS KMS key alias' is 'cybersec-trail'; 'Log file validation' is 'Enabled'; 'Last file validation delivered' is 'May 18, 2026, 11:58:58 (UTC+05:30)'; 'SNS notification delivery' is 'Disabled'; and 'Last SNS notification' is '-'. An 'Edit' button is located to the right of the 'General details' section. Below this, the 'CloudWatch Logs' section shows the 'Log group' as 'aws-cloudtrail-logs-660830512345-f093870f-sprint' and the 'IAM Role' as 'arn:aws:iam:660830512345:role/service-role/CloudTrailRoleForCloudWatchLogs'. An 'Edit' button is also present to the right of this section.

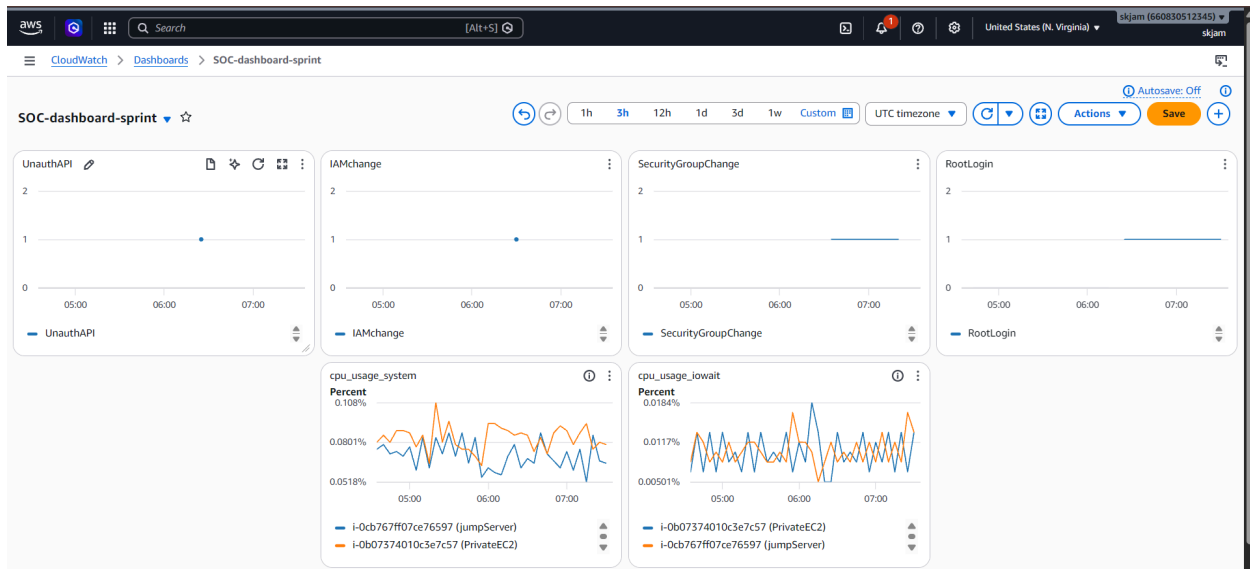
CloudTrail

CloudWatch > Alarms

Alarms (5)

Name	State	Actions	Actions muted - new	Last state update (UTC)	Condition
SecurityGroupChangeAlarm	OK	Actions enabled	-	2026-05-18 06:38:35	SecurityGr within 5 m
IAMChangeAlarm	In alarm	Actions enabled	-	2026-05-18 06:35:34	IAMchange minutes
UnauthAPI	OK	Actions enabled	-	2026-05-18 06:29:37	UnauthAP minutes
RootLoginAlarm	In alarm	Actions enabled	-	2026-05-18 06:28:01	RootLogin minutes
FailedLoginAlarm	Insufficient data	Actions enabled	-	2026-05-16 13:51:43	FailedLogi minutes

Metric Filter Alarms



SOC Dashboards

660830512345/

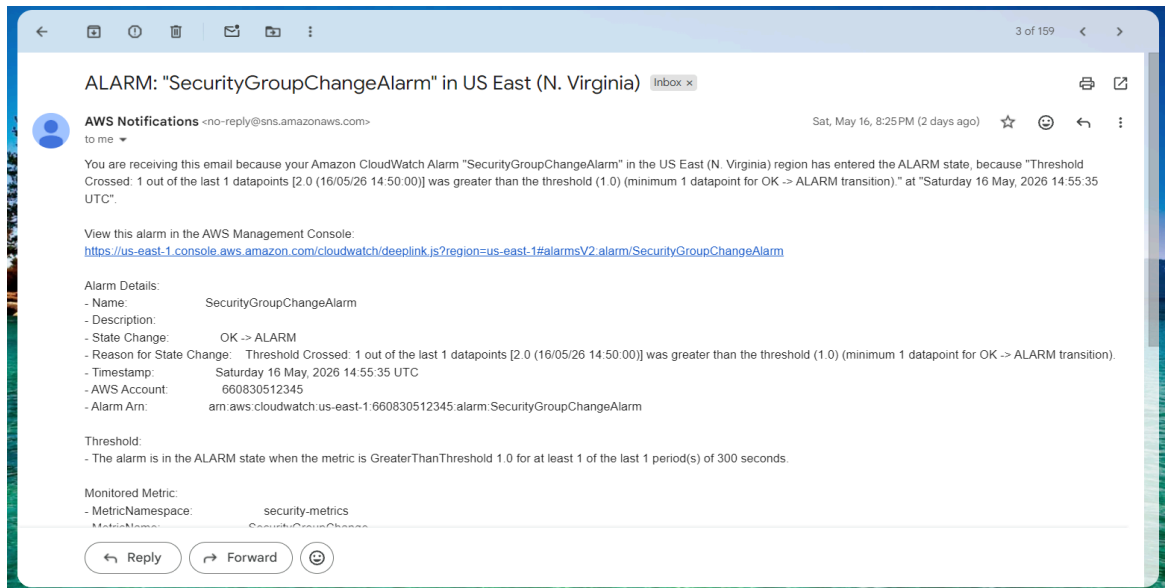
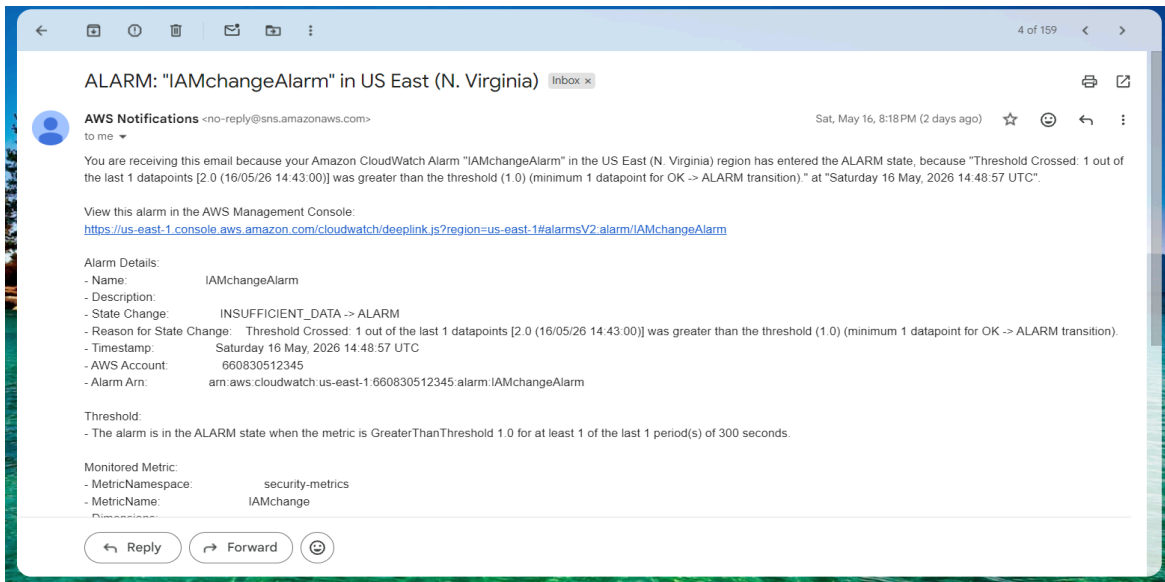
Copy S3 URI

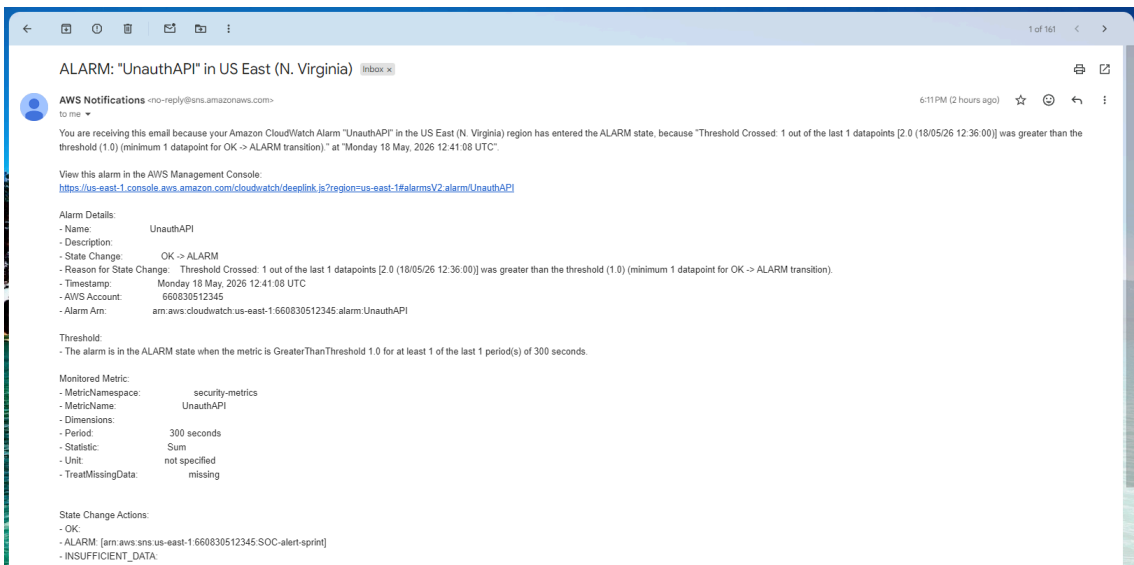
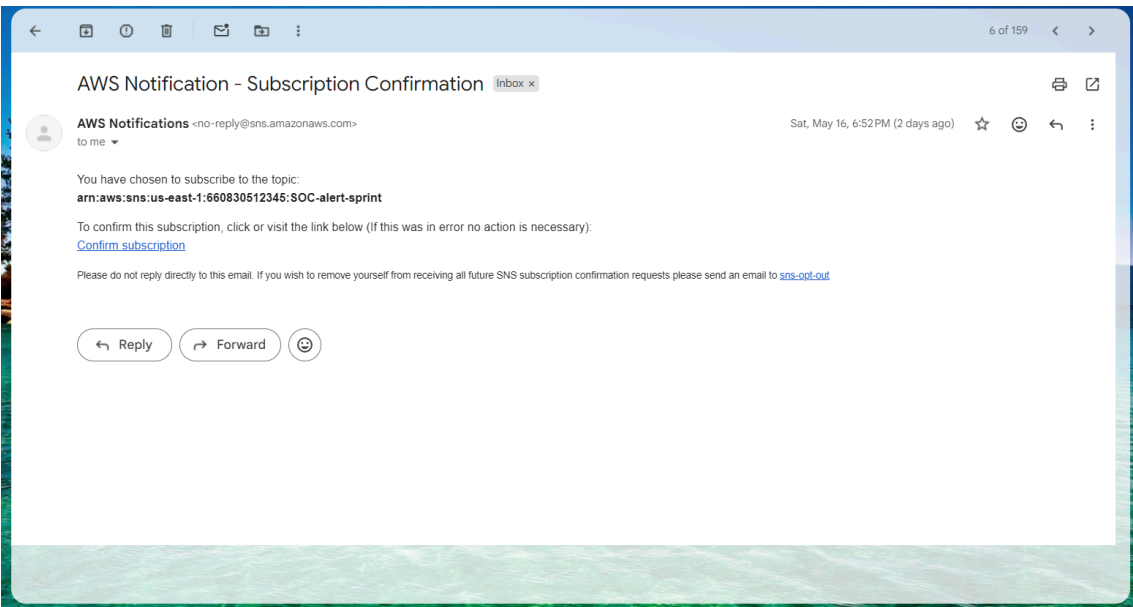
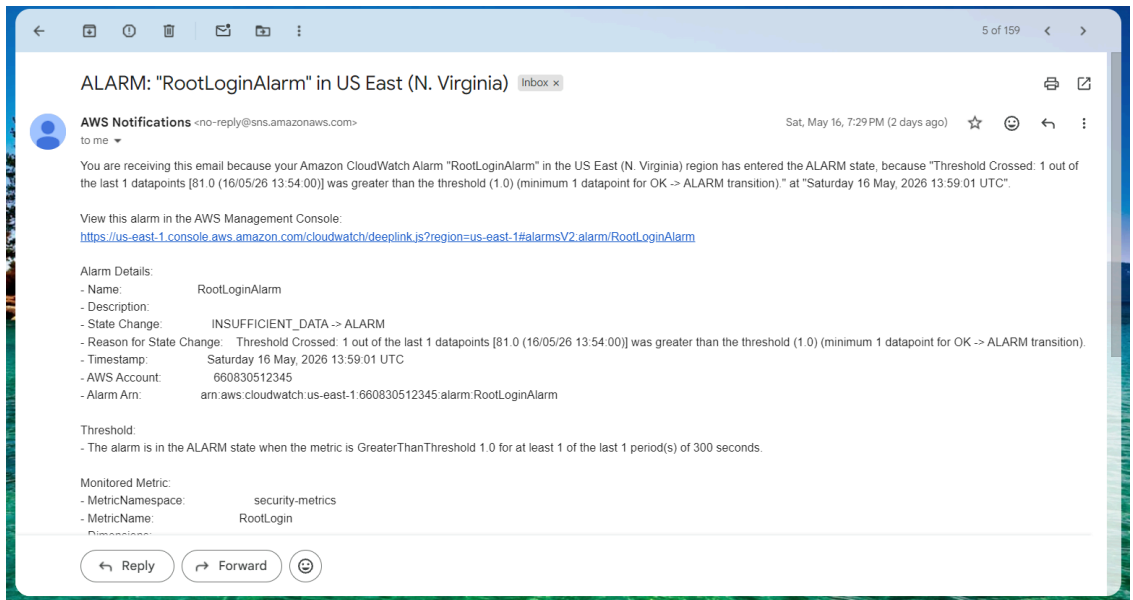
Objects (3)

Find objects by prefix

Name	Type	Last modified	Size	Storage class
CloudTrail-Digest/	Folder	-	-	-
CloudTrail-Insight/	Folder	-	-	-
CloudTrail/	Folder	-	-	-

Logs On S3





Alert Emails